SECURITY SELF-ASSESSMENT

众安 Agent 安全自评报告

权限分级实现说明 · 一次性票据与强验证 · 防御纵深 · 已知风险清单

	查询 query	确认 confirm	完全 full
绿色 • 只读/界面	— 仅生成计划	— 仅生成计划	√ 直接执行
黄色 • 小额资金	— 仅生成计划	√ 必须密码	√ 策略内免密 / 超限密码
红色 • 强验证/大额	— 仅生成计划	√ 密码 + 一次性票据	√ 密码 + 一次性票据

最终等级与是否免密由服务端策略引擎计算；界面模式与模型输出不能覆盖。

版本 1.0 · 2026-10-31 · 覆盖提交版本 server.mjs / db.mjs / channels/im.mjs

本报告回答两个问题：权限分级是如何在服务端落地的；当前实现里哪些风险是已知的、缓解到什么程度、哪些是有意保留的演示口径。所有结论均可对照代码与测试复现。

目录

1. 评估范围与方法
2. 权限模型总览：三级权限 × 三色风险
3. 权限分级实现说明
4. 一次性票据与强验证生命周期
5. 防御纵深：注入、限流、熔断、访客隔离与审计链
6. 已知风险清单
7. 演示口径的特殊说明
8. 评估局限与后续计划

阅读口径

「已闭环」指当前代码中该路径已被阻断并有测试覆盖；「缓解中」指存在纵深但覆盖不完备；「已知取舍」指有意接受的限制；「规划中」指列入生产化清单。自评不等同于第三方渗透测试。

1. 评估范围与方法

评估对象为提交版本的服务端（server.mjs）、数据层（db.mjs）、IM 适配器（channels/im.mjs）与单页前端（index.html）。方法：以「攻击者能否让系统执行一笔未被用户明确授权的资金动作」为第一判据，以「评审者能否从回执与审计判断真实状态」为第二判据；对每条路径做代码走查 + 接口实测 + 浏览器端到端验证（smoke 329 条、IM 通道 55 条、访客隔离 25 条、静态与接口契约 check）。

评估维度	手段	证据形态
权限语义	代码走查 + 三色矩阵逐格实测	本文第 2、3 节
资金动作	密码正确/错误、票据重放、跨会话确认	smoke + im:check 用例
注入与边界	特征输入实测 + 提示词结构审查	审计 red 记录
部署面	限流、静态白名单、密钥不回显	curl 实测记录
数据一致性	db:check 余额/订阅/审计口径	SQL 断言输出

2. 权限模型总览：三级权限 × 三色风险



图 1 请求携带 permission（query/confirm/full）；每个动作节点由服务端计算 green/yellow/red，矩阵右下角是唯一的资金执行通道。

三条硬规则：

• query 模式只生成计划，任何资金与授权节点都不执行（服务端短路，不依赖前端自觉）。

• confirm 模式强制逐笔密码（forcePassword），即使节点落在免密策略内。

• full 模式也不等于免密：绿色直接执行；黄色按策略（自动批准 + 阈值 + 本人互转 + 订阅/缴费开关）决定免密或密码；红色一律票据 + 密码。

模型输出（green/yellow/red 建议）只作为风险提示展示，最终等级由服务端按节点类型、金额与账户归属重算；这消除了「模型把大额转账说成 green」的降级路径。

3. 权限分级实现说明

3.1 请求入口与权限字段

POST /api/agent { text, userId, permission: 'query'|'confirm'|'full', pending?, password? }
permission='confirm' -> forcePassword = true（逐笔强确认）
permission='query' -> 动作节点在 executeAgentStep 入口直接返回 blocked

3.2 节点等级计算（服务端，模型不可覆盖）

节点类型	等级	执行条件
set_ui / manage_quick_service	green	直接执行，不涉及资金
transfer_money ≤ ¥1,000	yellow	自动批准开启且命中策略时免密，否则密码
transfer_money > ¥1,000	red	必须支付密码（票据确认）
subscribe / cancel / pay_bill	yellow	自动批准开启时免密，否则密码
set_auto_approve	red	策略变更本身需要密码
schedule_transfer 及未列明类型	red	默认最严：必须支付密码

3.3 策略引擎（full 模式下黄色节点的免密判定）

allowed = !forcePassword && policy.autoApprove
&& (本人账户互转 ? policy.allowInternal : amountCents <= policy.thresholdCents)
订阅续费 -> policy.allowSubscription 生活缴费 -> policy.allowUtility
默认策略：自动批准关闭 · 免密阈值 ¥1,000 · 互转允许 · 订阅/缴费允许

3.4 确认模式与红色强验证

红色节点无条件进入 needsPassword 分支：服务端不执行，改为签发一次性票据并返回 pending；用户在 Web/App 确认页输入 6 位支付密码后经 /api/agent/confirm 重放原始参数执行。确认页与会话绑定（访客 Cookie 校验），跨会话打开返回 403 TICKET_SESSION_MISMATCH。

3.5 挂失与卡片级权限

账户挂失即时生效：frozen 状态下转账在数据层被拒；解除挂失需要密码。卡凭据（6 位支付密码）按账户存储，错误次数累计并在连续失败时触发渠道熔断（见第 5 节）。

4. 一次性票据与强验证生命周期

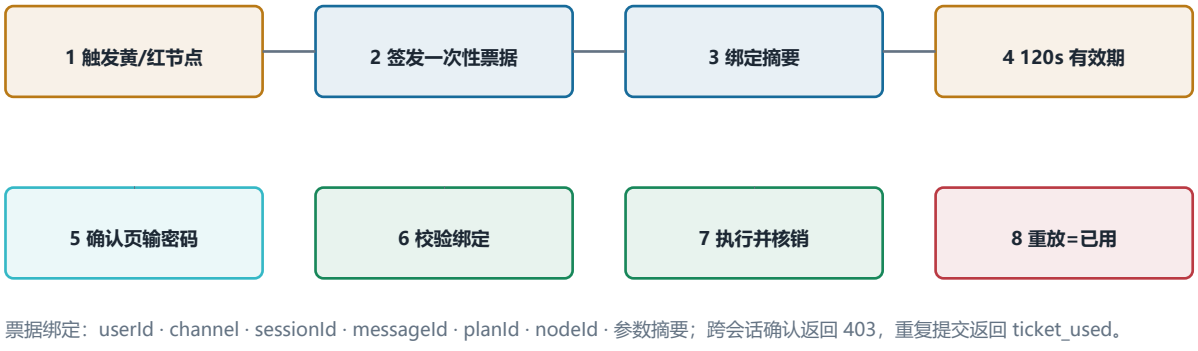


图 2 黄/红节点的统一强验证通道：服务端按票据重读原始参数，请求体篡改无效。

实现要点

- 票据持久化于 SQLite agent_tickets（重启不丢失），绑定 userId、channel、sessionId、messageId、planId、nodeId、工具名、参数摘要与过期时间（120 秒）。
- 确认接口重新读取票据中的原始参数并比对摘要：把 100 元确认改成 5000 元会因摘要不一致被拒。
- 一次性核销：已确认票据重复提交返回 ticket_used；过期提交返回「密码确认已过期」，账户分文未动。
- 密码连续失败 5 次/10 分钟触发渠道熔断 circuit_open，15 分钟内拒绝该渠道资金动作并写入审计。
- 支付密码只出现在 Web/App 确认页；IM 消息通道任何情况下不传输密码。

5. 防御纵深：注入、限流、熔断、访客隔离与审计链

5.1 提示词注入（三层）

第一层输入特征筛查：忽略指令、角色扮演、越狱关键词命中即短路，返回红色决策并写审计；第二层提示词结构：对话历史与界面上下文以「不可信资料」角色注入；第三层执行语义：红色节点必须持票据与密码，模型等级只作提示。

5.2 限流与熔断（公开免口令部署）

机制	阈值	作用范围
AI 接口限流	30 次 / 10 分钟 / IP	/api/agent、/api/ai/test、/api/channel/selftest、/api/tts
访客创建限流	10 次 / 10 分钟 / IP	新建访客工作区
密码熔断	5 次失败 → 15 分钟锁定	按 用户+渠道，仅资金动作
静态白名单	白名单外一律 404	全部静态路径（含点号路径）

5.3 访客工作区隔离

每个浏览器/企微用户克隆模板用户生成 v-/w- 前缀独立工作区，后续请求由服务端强制注入 userId；跨工作区转账在执行器入口直接拒绝；总容量按字节 ×1.7 估算，超过 100MB 按 LRU 淘汰最久未访问工作区，审计行保留以维持链式哈希连续。

5.4 审计链

每条审计覆盖：userId, channel, sessionId, messageId, planId, nodeId, level, decision, inputDigest, resultRef, prevHash, hash（SHA-256 链）
设置 → 安全动态 可现场校验链完整性与最近事件三色计数

5.5 模型接入安全

默认硅基流动免费模型；自定义网关凭据经 base64 X-AI-Config 头单次转发，不入库、不写日志、不在接口回显（公开模式 apiKeyMasked 为空）；网关地址拒绝内网与本机目标（SSRF 防护）；上游失败返回 502 可重试，不存在离线伪回答。

6. 已知风险清单

下表为当前实现的诚实清单：含已闭环的历史发现、缓解中的纵深缺口、已知取舍与有意保留的演示口径。

级别	风险	影响	缓解 / 状态
高	多动作计划非原子执行	同一计划前一步成功、后一步失败时出现部分完成	按节点签发票据、逐节点确认，回执明示已执行/未执行；不做跨节点回滚。已知边界
高	注入第一层为正则筛查	同义改写、分段编码可能绕过特征层	第二层提示词隔离 + 第三层执行语义兜底（等级重算、红色票据+密码）；特征库持续扩充。缓解中
中	普通请求未绑定不可变计划签名	同会话旧计划文本可被重放为上下文，审计上下文不完整	planId 与 inputDigest 已入审计；票据本身绑定参数摘要。规划中
中	审计载荷未含来源 IP 与确认页版本	跨渠道追溯颗粒度不足	现覆盖 channel/session/message/plan/node/digest/resultRef；字段扩展列入生产化清单。规划中
中	演示口径展示完整卡号与明文查询密码	评审可见敏感形态数据	全部为虚构模拟数据；该口径仅为演示便利，生产化清单首项即移除。有意保留（演示）
中	EXE/APK 未做代码签名	Windows SmartScreen 与安卓未知来源提示	便携包不写注册表；正式发布前购买证书签名。规划中
低	公开限流按出口 IP 共享	同一 NAT/办公网多人共享 30 次/10 分钟	可经 PUBLIC_RATE_LIMIT 调整；确认页与浏览不受限。已知取舍
低	/api/health 返回版本/模型/工具清单	增加指纹面	不含密钥与路径；可按环境收敛输出。已知取舍
低	未部署严格 CSP（内联脚本）	XSS 纵深不足	输出统一 escapeHtml，无用户生成 HTML 注入点；CSP 列入生产化清单。规划中
低	SQLite 单文件并发写	高并发下写排队	单实例部署；不支持多副本共享同一数据库文件。架构约束

已闭环的历史发现（供答辩引用）

- 票据曾存于内存，重启即失——已迁移 SQLite agent_tickets，重启后可确认、重放返回 ticket_used。
- schedule_transfer 分支曾引用越界变量触发 ReferenceError——已改为票据 + 密码确认路径并纳入确认白名单。
- 红色等待态曾被显示为「已拦截」——状态词已拆分 blocked / waiting_strong_auth / executed。

7. 演示口径的特殊说明

为便于现场演示，欢迎资料展示完整卡号与明文查询密码、界面不出现免责与风险类文案（以真实状态、回执单号与审计记录代替警示语）。这是有意的产品口径而非疏漏：所有账户、流水、订阅与产品均为虚构模拟数据，不接真实银行；资金动作的真实约束由服务端策略引擎与票据体系承担。生产化交付时，移除演示口径（首项）与接入真实行内系统是两条前置条件。

8. 评估局限与后续计划

- 本报告为自评，不构成第三方渗透测试结论；外部模型审查通道在评估期内不可用（如实记录），未把未完成的调用描述为模型审查结论。
- 未覆盖：移动端逆向、内核级提权、物理接触、供应链（依赖为零 npm 运行时依赖，开发工具链除外）。
- 后续计划：计划签名绑定普通请求、审计字段扩展（IP/确认页版本）、严格 CSP、代码签名、真实行内系统对接评估。

文档版本：1.0 · 2026-10-31 · 对应验收基线 smoke 329 条 / im:check 55 条 / visitor:check 25 条